UNIVERSIDAD SERGIO ARBOLEDA
Bogotá D.C.

Parcial 2 – Seguridad de la información y gestión de riesgos

Análisis de riesgos de seguridad de la información en Empresas Públicas de Medellín E.S.P. (EPM)

Referencias normativas: ISO/IEC 27001:2022 (Anexo A) e ISO 31000:2018

Estudiante: Andrés Felipe Céspedes Rondón
Profesor: MSc. Iván Darío Méndez Aguilera
Asignatura / grupo: Ciberseguridad 2026 – G01
Fecha: Octubre de 2026

Trabajo académico elaborado solo con información pública. Todo lo marcado con **[S]** es un supuesto ficticio con fines académicos.
No se realizaron pruebas sobre sistemas de EPM ni de sus filiales.

Contenido

Resumen ejecutivo
1. Contexto de la organización y metodología
2. Actividad 1: Reglas internas de seguridad
3. Actividad 2: Inventario de activos de información
4. Actividad 3: Vulnerabilidades (CVE)
5. Actividad 4: Análisis y evaluación de riesgos (ISO 31000)
6. Actividad 5: Matriz de evaluación y tratamiento
7. Actividad 6: Mapa de calor inherente y residual
8. Actividad 7: Plan de tratamiento de riesgos
9. Actividad 8: Caso de incidente (escenario ficticio)
10. Actividad 9: Conclusiones
Referencias

Resumen ejecutivo

EPM es la matriz del Grupo EPM, que agrupa 48 empresas de servicios públicos en seis países y atiende a más de 10,1 millones de clientes y usuarios; solo EPM atiende 3.055.731 clientes y tiene 8.558 colaboradores [15]. Opera infraestructura crítica de energía, gas, agua y saneamiento, por lo que un incidente digital puede pasar de afectar oficinas a afectar el servicio de millones de personas. Esto ya ocurrió: el 12 de diciembre de 2022 EPM sufrió un ataque de ransomware atribuido a BlackCat/ALPHV que dejó caídos sus canales digitales, envió a unos 4.000 empleados a trabajar desde casa y afectó la recarga de más de 300.000 familias con prepago [16, 17].

Con información pública verificable y supuestos marcados con [S], este informe propone 6 reglas internas que no están explícitas en las políticas publicadas por EPM, construye un inventario de 12 activos, analiza 10 vulnerabilidades reales (todas en el catálogo KEV de CISA) y evalúa 12 riesgos con el proceso de ISO 31000. El resultado inherente es de **2 riesgos críticos, 9 altos y 1 medio**. Con el plan de tratamiento propuesto (11 acciones, 12 meses, COP 12.150 millones [S]) el residual esperado es de **1 alto, 8 medios y 3 bajos**.

Riesgos prioritarios:

1. **R01 – Ransomware en TI** que detiene facturación, prepago y canales digitales (nivel 20, crítico).
2. **R05 – Filtración masiva de datos personales de clientes** por doble extorsión (nivel 20, crítico).
3. **R02 – Compromiso del acceso remoto y del perímetro** (VPN, ADC, firewall) (nivel 16, alto).

Medidas clave: MFA en todo acceso remoto y privilegiado, parcheo urgente de equipos de borde, administración por niveles con bóveda de credenciales, respaldos inmutables probados, segmentación TI/OT con acceso remoto por bastión y un plan de respuesta a incidentes ensayado con la junta. El riesgo de sabotaje del SCADA de energía (R03) queda en nivel alto aun después del plan y debe seguirse a nivel de junta.

1. Contexto de la organización y metodología

1.1 Perfil de la empresa (información pública)

- **Razón social y naturaleza:** Empresas Públicas de Medellín E.S.P., empresa de servicios públicos de naturaleza 100 % pública, propiedad del Distrito de Medellín. Desde el 12 de mayo de 2025 separa su rol de matriz (direccionador del Grupo) y de empresa ejecutora [15].
- **Servicios:** generación, transmisión, distribución y comercialización de energía; gas; acueducto, alcantarillado y aseo. Es el primer agente en producción de energía del Sistema Interconectado Nacional [15].
- **Escala:** Grupo con 17.606 personas y 10.148.985 clientes y usuarios en Colombia, Chile, El Salvador, Guatemala, México y Panamá; EPM con 8.558 colaboradores y 3.055.731 clientes [15].
- **Tecnología mencionada públicamente:** implementación del ERP SAP S/4HANA con alcance de Grupo, SAP Ariba en la nube, IBM Maximo, GIS, sistemas SCADA, medidores inteligentes (AMI) y Microsoft Power Platform [15]. El plan de tecnología 2026 incluye integración TI–TO, adopción de inteligencia artificial y un DRP por negocio que integre TI y TO [12].
- **Gobierno de ciberseguridad:** Dirección de Ciberseguridad con una estrategia 2024–2027 organizada en gobernar, identificar, proteger, detectar, responder y recuperar, y un SOC [7, 15]. En octubre de 2025 la Junta

suprimió su Comité de TI y Ciberseguridad y pasó la supervisión del riesgo de ciberseguridad al Comité de Auditoría y Riesgos [15].

1.2 Antecedente: ransomware de diciembre de 2022

El ataque empezó la tarde del 12 de diciembre de 2022 [17]. BleepingComputer confirmó con una muestra del cifrador y las notas de rescate que correspondía a BlackCat/ALPHV, y un investigador encontró un servidor del atacante con datos de un poco más de 40 equipos de EPM, lo que indica robo de información antes del cifrado [16]. Un informe interno filtrado (nunca publicado oficialmente) habló de pérdida de control de la plataforma, pérdida de respaldos y afectación de cerca del 25 % de la infraestructura [17]. Filiales como ESSA y Afinia también tuvieron que suspender canales digitales, y las recargas de prepago se restablecieron por medio de aliados como Nequi, GANA y PSE [18]. EPM no ha publicado el vector de entrada; en su lista pública de auditorías aparece una «Consultoría incidente ciberseguridad» cerrada el 27/12/2022 [14].

1.3 Marco normativo considerado

Ley 1581 de 2012 de protección de datos personales [42]; Ley 1273 de 2009 de delitos informáticos [43]; Resolución MinTIC 500 de 2021 (Modelo de Seguridad y Privacidad de la Información) y Acuerdo 1502 de 2021 del Consejo Nacional de Operación (CNO), guía de ciberseguridad del sector eléctrico, ambos citados por EPM en su lineamiento de seguridad digital [6]; Decreto 338 de 2022 sobre gobernanza de la seguridad digital del Estado [44]. EPM también evaluó en 2025 la implementación de la guía de ciberseguridad TO del Acuerdo CNO 1960 [14].

1.4 Metodología y alcance

Se siguió el proceso de ISO 31000:2018 [2]: establecer contexto y criterios, identificar, analizar y valorar riesgos, tratarlos y definir seguimiento. Los controles se toman del Anexo A de ISO/IEC 27001:2022 [1] y, para redes industriales, se usa como apoyo la idea de zonas y conductos de IEC 62443 [4]. El alcance son los procesos de prestación del servicio (TO), comerciales y corporativos (TI) de EPM matriz. Las fuentes se consultaron el 29/10/2026. Los responsables, cifras de impacto, presupuestos y el inventario de activos son supuestos [S]. Que un CVE se relacione con un tipo de tecnología no significa que EPM sea vulnerable: no hay evidencia pública de que use esas versiones.

2. Actividad 1: Reglas internas de seguridad

2.1 Documentos públicos revisados

Se descargaron las políticas publicadas en la sección «Políticas» y en «Transparencia» del sitio de EPM, se extrajo su texto y se buscaron los términos de cada regla sin tildes ni mayúsculas. Luego se leyó el contexto de cada coincidencia.

Tabla 1. Documentos revisados (consulta: 29/10/2026).

ID	Documento	Contenido relevante
D1	Política de seguridad de la información y ciberseguridad del Grupo EPM (Acta 1619 de Junta, 13/12/2016) y su Lineamiento 2023-LINGG-115 «Seguridad digital y continuidad de los servicios de tecnología» (23/02/2023) [5, 6]	Protección de activos críticos y ciberactivos, firma electrónica, inventario de activos, respuesta a incidentes, continuidad y concienciación.
D2	Estrategia de Seguridad de la Información y Ciberseguridad 2024–2027 [7]	Retos (controles para Aguas, Gas y Energía; servicios del SOC; continuidad de TI) y seis líneas de capacidad.
D3	Lineamiento sobre protección de datos personales (Decreto 2013-DECGGL-1946, rev. 003 de 23/09/2019) [8]	Principios, derechos, deberes, prohibiciones, transferencias y medidas de seguridad por niveles.
D4	Política de Gestión Ética y Cumplimiento (Acta 1801, 01/10/2024) [9]	Declaración ética y de cumplimiento normativo.
D5	Política de cero tolerancia frente al fraude, la corrupción y el soborno [11]	Gestión general del riesgo de fraude.
D6	Plan Estratégico Integrado 2026 de la Gerencia Tecnologías y Procesos (PETI) [12]	Iniciativas: integración TI–TO, IA, DRP, gobierno de datos.

ID	Documento	Contenido relevante
D7	Página de políticas: gestión integral de riesgos (2010), gestión de TI (2011), gestión de la información (2014), resiliencia organizacional (2023) y política digital [5]	Declaraciones de una o dos frases, sin reglas operativas.
D8	Código de Ética del Grupo EPM [10]	Principios y valores (transparencia, calidez, responsabilidad).

La Política de Seguridad de EPM de 2018 [13] es un certificado escaneado sin texto, así que no se pudo buscar automáticamente; se leyó a mano y trata de seguridad física de personas, infraestructura y reputación, sin controles digitales. Los documentos internos del SGSI que cita D1 (por ejemplo el glosario «O-SGSI-A01-002») están en la intranet de EPM y no son públicos, por lo que no se revisaron.

2.2 Búsquedas realizadas y resultado

Tabla 2. Términos buscados en D1–D8 y resultado por regla.

Regla	Términos buscados	Resultado
RI-01	«acceso remoto», «remoto», «SCADA», «industrial», «segmentación», «OT/TO»	0 coincidencias para los cinco primeros. «TO» solo aparece en la política digital (tecnologías «TI, TO y TC») y en la iniciativa «Integración TI-TO» de D6, sin reglas de acceso.
RI-02	«privilegiado», «administrador», «contraseña», «multifactor / MFA / doble factor», «credencial»	D1 nombra «contraseñas» solo como ejemplo de firma electrónica (nota al pie). «Privilegiando» (D4, D7) y «administradores» (D5) tienen otro sentido. MFA y credencial: 0.
RI-03	«internet», «expuesto / exposición», «superficie», «parche», «vulnerabilidad», «configuración»	D3 dice que los datos personales no podrán estar en internet para consulta abierta (publicación de datos, no servicios). D2 menciona la «gestión de vulnerabilidades» como servicio del SOC, sin criterios. D1 pide mantener el inventario de activos críticos, pero no trata la exposición a internet. «Parche» y «superficie»: 0.
RI-04	«log», «registro de eventos», «bitácora», «trazabilidad», «retención», «sincronización», «monitoreo»	0 coincidencias salvo «monitorear»: D1 pide «monitorear permanentemente la infraestructura tecnológica», sin fuentes, retención ni sincronización de relojes.
RI-05	«suplantación», «phishing», «cuenta bancaria», «pago», «correo»	D1 usa «suplantación de identidad» solo para justificar la firma electrónica de documentos. D5 gestiona el fraude en general, sin procedimiento de verificación de pagos. «Phishing» y «cuenta bancaria»: 0.
RI-06	«pruebas», «ambiente de desarrollo / pruebas», «enmascaramiento», «anonimización», «seudonimización»	D3 solo menciona «pruebas sicotécnicas» de selección y medidas «físicas, lógicas y administrativas» en tres niveles (numeral 15), sin regla para ambientes no productivos. Resto: 0.

Conclusión de la revisión: las políticas públicas de EPM son declaraciones de alto nivel. Ninguna de las seis reglas está contemplada de forma explícita, aunque D1 y D2 dan la base para crearlas (inventario de ciberactivos, monitoreo, continuidad y SOC).

2.3 Reglas propuestas

Tabla 3. Reglas internas propuestas y controles del Anexo A de ISO/IEC 27001:2022.

ID	Regla	Justificación	Anexo A
RI-01	**Acceso remoto a redes OT solo por bastión.** Ningún empleado ni tercero se conecta directo a redes de generación, transmisión, distribución o plantas de agua. Se entra por un bastión en la DMZ industrial con MFA, cuenta nominal, ventana de tiempo aprobada y grabación de la sesión. Se prohíben módems, routers 4G y software de control remoto no autorizado en redes OT.	La integración TI–TO del PETI 2026 [12] aumenta los caminos hacia la operación. Hay explotación real de PLC expuestos en empresas de agua [39].	5.15, 8.5, 8.20, 8.22
RI-02	**Administración por niveles.** Las cuentas con privilegios sobre Directorio Activo, hipervisores, respaldos y equipos de red son nominales, distintas de la cuenta de correo, se usan solo desde estaciones de administración dedicadas y se guardan en una bóveda con rotación y MFA. Hipervisores y servidor de respaldos no se unen al dominio de usuarios.	En 2022 se reportó pérdida de control de la plataforma y de los respaldos [17]. V04 y V05 muestran que el dominio es la llave de todo.	5.18, 8.2, 8.5

ID	Regla	Justificación	Anexo A
RI-03	**Superficie expuesta controlada.** Todo servicio publicado en internet debe estar en el inventario con un dueño y se revisa con un escaneo externo mensual. Las interfaces de administración (routers, firewalls, hipervisores, consolas de respaldo) y los equipos OT nunca se publican en internet.	Siete de los diez CVE de la sección 4 (V01, V02, V06–V10) se explotan por red y sin autenticación contra servicios que no deberían estar expuestos.	5.9, 8.9, 8.20, 8.21
RI-04	**Registros para investigar.** VPN, firewalls, controladores de dominio, correo, ERP, hipervisores, respaldos y estaciones de ingeniería OT envían sus registros al SOC con hora sincronizada (NTP) y retención mínima de 12 meses (90 días en línea). Solo el SOC puede borrarlos, con registro.	Tras el ataque de 2022 hubo versiones encontradas sobre el origen y no hubo prueba pública del primer servidor infectado [17].	5.28, 8.15, 8.16, 8.17
RI-05	**Verificación de pagos y marca.** Todo cambio de cuenta bancaria de proveedores o empleados, y toda orden de pago urgente que llegue por correo, se confirma por un segundo canal (llamada al número registrado en SAP/Ariba) con doble aprobación. Los dominios de EPM publican DMARC con política *reject* y se vigilan dominios y portales falsos.	EPM atendió en 2025 un «incidente de suplantación al portal factura web» [14]. Paga a miles de proveedores registrados en Ariba [15].	5.7, 5.14, 6.3
RI-06	**Sin datos reales en pruebas.** Se prohíbe copiar datos personales reales de clientes (sistema comercial, prepago, AMI) a ambientes de desarrollo, pruebas, capacitación o a proveedores de software. Se usan datos sintéticos o enmascarados; las excepciones requieren aprobación escrita del responsable de protección de datos y duran máximo 30 días.	La migración a SAP S/4HANA y el proyecto AMI [15] implican migraciones y pruebas con terceros sobre datos de 3,05 M de clientes.	5.34, 8.11, 8.31, 8.33

3. Actividad 2: Inventario de activos de información

Inventario ficticio [S] basado en la tecnología que EPM menciona públicamente. Cada activo se valora de 1 a 5 en confidencialidad, integridad y disponibilidad (C-I-D). Criticidad = valor máximo: 5 crítica, 4 alta, 3 media.

Tabla 4. Inventario de activos de información [S].

ID	Activo	Descripción	Responsable [S]	Clasificación	C-I-D	Criticidad
A01	SCADA/EMS de energía	Supervisión y control de generación, transmisión y distribución desde los centros de control; estaciones de ingeniería y controladores de centrales y subestaciones.	Gerente de Operación de Energía	Restringida	3-5-5	Crítica
A02	SCADA, PLC y HMI de agua	Control de plantas de potabilización, tanques, bombeo y tratamiento de aguas residuales.	Gerente de Provisión de Aguas	Restringida	3-5-5	Crítica
A03	ERP SAP S/4HANA y SAP Ariba	Finanzas, compras, contratación y mantenimiento de activos (integrado con IBM Maximo y GIS) [15].	Gerente de Tecnologías y Procesos	Confidencial	4-4-4	Alta
A04	Sistema comercial y de facturación	Lecturas, liquidación, facturación, recaudo y recargas de prepago de energía, agua y gas.	Vicepresidente Comercial	Confidencial	4-5-5	Crítica
A05	Base de datos de clientes	Datos personales de 3,05 M de clientes [15]: identificación, dirección, consumo, pagos y subsidios.	Jefe de la Unidad de Cumplimiento	Restringida	5-4-3	Crítica
A06	Portal web, app y factura web	Autogestión, consulta y pago en línea; integración con PSE y aliados de recaudo.	Jefe de Canales Digitales	Pública / Confidencial	3-4-4	Alta
A07	Directorio Activo e identidades	Cuentas de usuarios, servicios y administradores; certificados (AD CS) e inicio de sesión único.	Jefe de Infraestructura TI	Restringida	5-5-5	Crítica
A08	Correo corporativo e intranet	Comunicación y documentos de trabajo de 8.558 colaboradores [15].	Jefe de Infraestructura TI	Uso interno	4-4-4	Alta

ID	Activo	Descripción	Responsable [S]	Clasificación	C-I-D	Criticidad
A09	Plataforma de virtualización	Hipervisores y almacenamiento del centro de datos principal y del centro alterno (CAPD) [14].	Jefe de Infraestructura TI	Restringida	4-5-5	Crítica
A10	Plataforma de respaldo	Copias de servidores, bases de datos y configuraciones de TI.	Jefe de Continuidad de TI	Restringida	5-5-4	Crítica
A11	Perímetro y acceso remoto	Firewalls, VPN y controladores de entrega de aplicaciones para teletrabajo y terceros.	Jefe de Redes y Seguridad Perimetral	Restringida	4-5-5	Crítica
A12	Red de telecomunicaciones operativa	Routers, fibra óptica propia y enlaces WAN entre sedes, centros de control y subestaciones.	Jefe de Telecomunicaciones	Restringida	3-4-5	Crítica

4. Actividad 3: Identificación de vulnerabilidades (CVE)

Se eligieron diez CVE reales sobre tecnologías típicas de una empresa de servicios públicos con TI y TO: acceso remoto, correo, identidad, virtualización, respaldos, ERP, red y control industrial. Todos se verificaron en la NVD (CVSS v3.x) y en el catálogo KEV de CISA, versión 2026.10.29 [19]: **los diez están en KEV**, es decir, tienen explotación activa confirmada, y seis tienen uso conocido en campañas de ransomware. La columna «Relación» explica por qué el tipo de tecnología es pertinente para EPM; **no se afirma que EPM use esas versiones ni que sea vulnerable**.

Tabla 5. Vulnerabilidades analizadas (CVSS v3.x de la NVD; entre paréntesis, el del fabricante cuando difiere).

ID / CVE	Producto y falla	Impacto	CVSS / KEV	Relación posible con EPM	Mitigación
V01 CVE-2023-4966 «Citrix Bleed»	NetScaler ADC y Gateway configurados como VPN, ICA/RDP Proxy o AAA: desbordamiento que filtra memoria con tokens de sesión [20, 21].	Secuestro de sesiones ya autenticadas, saltando contraseña y MFA.	7.5 (9.4) KEV: sí (18/10/2023); ransomware: conocido [22]	A11: acceso remoto de empleados y terceros [S].	Actualizar a 14.1-8.50, 13.1-49.15, 13.0-92.19 o posteriores y terminar todas las sesiones activas [21].
V02 CVE-2024-3400	Palo Alto PAN-OS con GlobalProtect: creación arbitraria de archivos que lleva a inyección de comandos [23, 24].	Ejecución de código como root en el firewall, sin autenticación.	10.0 KEV: sí (12/04/2024); ransomware: conocido	A11: firewall perimetral con VPN [S].	Actualizar a 10.2.9-h1, 11.0.4-h1, 11.1.2-h3 o posteriores y revisar indicadores de compromiso [24].
V03 CVE-2022-41082 «ProxyNotShell»	Microsoft Exchange Server local: deserialización insegura por PowerShell remoto, encadenada con la SSRF CVE-2022-41040 [25, 26].	Ejecución remota de código en el servidor de correo.	8.0 (Microsoft) KEV: sí (30/09/2022); ransomware: conocido	A08 si el correo es Exchange local o híbrido [S]. Se explotó en 2022, pero no hay evidencia de que fuera el vector del ataque a EPM.	Aplicar la actualización de seguridad de noviembre de 2022 o posterior; restringir PowerShell remoto; evaluar correo en la nube.
V04 CVE-2022-26923 «Certifried»	Active Directory con AD CS: un usuario del dominio obtiene un certificado que lo hace pasar por un controlador de dominio [27, 28].	Escalamiento a administrador del dominio.	8.8 (Microsoft) KEV: sí (18/08/2022); ransomware: desconocido	A07: cualquier dominio Windows con servicios de certificados [S].	Actualizaciones de mayo de 2022 y modo de asignación fuerte de certificados (KB5014754); revisar plantillas de AD CS.
V05 CVE-2024-37085	VMware ESXi unido a AD: quien recrea el grupo «ESXi Admins» obtiene control total del host [29, 30].	Cifrado masivo de máquinas virtuales.	7.2 (6.8) KEV: sí (30/07/2024); ransomware: conocido [31]	A09: virtualización del centro de datos [S].	ESXi 8.0 U3 o posterior; en 7.0, configuración alternativa de VMSA-2024-0013; no unir ESXi al dominio [30].
V06 CVE-2024-40711	Veeam Backup & Replication: deserialización de datos no confiables [32, 33].	Ejecución remota de código sin autenticación en el servidor de respaldos.	9.8 KEV: sí (17/10/2024); ransomware: conocido	A10: plataforma de respaldo [S]. En 2022 se reportó pérdida de respaldos [17].	Actualizar a 12.2 (build 12.2.0.334) o posterior; sacar el servidor del dominio; repositorio inmutable [33].

ID / CVE	Producto y falla	Impacto	CVSS / KEV	Relación posible con EPM	Mitigación
V07 CVE-2025-31324	SAP NetWeaver Visual Composer: el Metadata Uploader no exige autorización [34, 35].	Carga de archivos ejecutables (webshell) sin autenticación.	9.8 (10.0) KEV: sí (29/04/2025); ransomware: conocido	A03: EPM usa SAP (S/4HANA, Ariba) [15]; no se sabe si tiene NetWeaver Java con Visual Composer [S].	Nota de seguridad SAP 3594142; deshabilitar Visual Composer si no se usa; buscar webshells [35].
V08 CVE-2023-20198	Cisco IOS XE con la interfaz web (HTTP Server) habilitada: crea una cuenta de privilegio 15 sin autenticación [36, 37].	Control total del router o switch.	10.0 KEV: sí (16/10/2023); ransomware: desconocido	A12: routers de sedes y subestaciones [S].	Deshabilitar el servidor HTTP en equipos expuestos y actualizar a una versión corregida (p. ej. 17.9.4a) [37].
V09 CVE-2023-6448	PLC y HMI Unitronics Vision/Samba con contraseña administrativa por defecto (VisiLogic < 9.9.00) [38].	Control administrativo del PLC por red.	9.8 KEV: sí (11/12/2023); ransomware: desconocido	A02: CISA reportó su explotación contra empresas de agua en 2023 [39]. Se usa como ejemplo del tipo de PLC de plantas [S].	Cambiar la contraseña, actualizar a VisiLogic 9.9.00, sacar el PLC de internet y cambiar el puerto por defecto [39].
V10 CVE-2021-22681	Controladores Rockwell Logix (ControlLogix, CompactLogix, GuardLogix) y Studio 5000: la clave de verificación se puede descubrir [40, 41].	Una aplicación no autorizada se conecta al controlador y cambia su lógica.	9.8 KEV: sí (05/03/2026); ransomware: desconocido	A01: controladores de centrales y subestaciones [S].	Selector del controlador en RUN, CIP Security, segmentar la red OT y bloquear el puerto 44818 desde redes no OT [41].

Fuentes: NVD (CVSS y descripción), boletín del fabricante y catálogo KEV de CISA [19] para cada CVE; ver números entre corchetes. «Ransomware: conocido / desconocido» es el campo *knownRansomwareCampaignUse* del catálogo KEV.

5. Actividad 4: Análisis y evaluación de riesgos (ISO 31000)

5.1 Partes interesadas

Tabla 6. Partes interesadas en la seguridad de la información de EPM.

Parte interesada	Interés o expectativa	Tipo	Riesgos
Clientes y usuarios (3,05 M en EPM) [15]	Energía, agua y gas continuos; datos protegidos; canales de pago confiables.	Externa	R01, R03, R04, R05, R07
Distrito de Medellín y Junta Directiva	Continuidad, reputación y transferencias; el Comité de Auditoría y Riesgos supervisa la ciberseguridad desde octubre de 2025 [15].	Interna	Todos
Colaboradores (8.558) [15]	Herramientas disponibles y protección de sus datos personales.	Interna	R01, R06, R07
Dirección de Ciberseguridad, SOC y Gerencia de Tecnologías y Procesos [7, 12]	Recursos, prioridades claras y autoridad para aplicar el plan.	Interna	Todos
Filiales del Grupo EPM	Servicios compartidos; en 2022 ESSA y Afinia también suspendieron canales [18].	Grupo	R01, R02, R06
Proveedores, contratistas e integradores OT	Reglas de acceso claras y estables en los contratos.	Externa	R03, R09, R11
SSPD, CREG, CNO y XM	Calidad y continuidad del servicio; guía de ciberseguridad del CNO [6].	Reguladora	R01, R03, R04, R10
Superintendencia de Industria y Comercio (SIC)	Cumplimiento de la Ley 1581 y reporte de incidentes con datos personales [42].	Reguladora	R05, R12
MinTIC, ColCERT y Fiscalía	Gestión de incidentes de seguridad digital y denuncia de delitos informáticos [43, 44].	Autoridad	R01, R03, R05
Acreedores y calificadoras	Estabilidad financiera; Moody's advirtió en 2022 el riesgo del ataque para la operación [18].	Externa	R01, R05

5.2 Criterios de valoración

Nivel de riesgo = probabilidad (P) × impacto (I), de 1 a 25. El impacto se toma como la peor consecuencia entre las dimensiones de la Tabla 9. Los umbrales económicos son ficticios [S], pero se calibraron con lo ocurrido en 2022: más de 300.000 familias sin recarga de prepago y canales caídos varios días [17] corresponde a un impacto 4 o 5.

Tabla 7. Escala de probabilidad.

P	Nivel	Criterio
1	Rara	No se espera en 5 años; sin precedentes en el sector.
2	Improbable	Una vez en 3 a 5 años; exige acceso previo y varias fallas.
3	Posible	Una vez en 1 a 3 años; ya pasó en empresas del sector.
4	Probable	Al menos una vez al año; exploit en KEV o ya ocurrió en EPM.
5	Casi cierta	Continua o varias veces al año (phishing, escaneos).

Tabla 8. Niveles de riesgo y respuesta.

Nivel	Rango	Respuesta
Bajo	1–4	Se acepta; revisión anual.
Medio	5–9	Seguimiento trimestral; tratar si es barato.
Alto	10–16	Tratar en máximo 12 meses; informe al comité.
Crítico	20–25	Tratar de inmediato; seguimiento de la junta.

Tabla 9. Escala de impacto (montos ficticios [S]).

I	Nivel	Servicio	Datos personales	Financiero	Legal y reputacional
1	Insignificante	Sin efecto en clientes; menos de 1 h interno.	Sin datos personales.	< COP 50 M	Sin efecto externo.
2	Menor	Proceso interno detenido < 8 h.	< 1.000 registros.	COP 50–500 M	Quejas aisladas.
3	Moderado	Una zona o canal digital caído < 24 h.	Hasta 100.000 registros.	COP 0,5–5 mil M	Requerimiento de SIC o SSPD; prensa local.
4	Mayor	Varios servicios o más de 300.000 clientes, 1 a 3 días.	Más de 100.000 registros.	COP 5–50 mil M	Investigación formal; prensa nacional.
5	Catastrófico	Cortes masivos de energía o agua, o riesgo para la salud pública.	Más de 1 millón de registros.	> COP 50 mil M	Sanciones máximas (hasta 2.000 SMMLV por la Ley 1581, art. 23 [42]); intervención.

5.3 Valoración del riesgo inherente

Tabla 10. Riesgos identificados y nivel inherente (sin los controles propuestos).

ID	Riesgo	Activos	CVE	Justificación de P e I	P	I	Nivel
R01	Ransomware en TI que detiene facturación, prepago y canales digitales	A04, A06, A07, A09, A10	V03–V06	Ya ocurrió en 2022 [16, 17]; varios CVE con uso conocido en ransomware. Afectó a más de 300.000 familias.	4	5	**20 Crítico**
R02	Compromiso del acceso remoto y del perímetro	A11	V01, V02	Los equipos de borde son de los más explotados del KEV; abren la puerta a R01 y R05.	4	4	**16 Alto**
R03	Sabotaje o manipulación del SCADA de energía	A01, A12	V10, V08	Exige conocimiento especializado, pero la integración TI–TO [12] abre caminos. Consecuencia física: cortes masivos.	3	5	**15 Alto**
R04	Ataque a PLC y HMI de plantas de agua	A02	V09	Ataques reales a empresas de agua en 2023 [39]. Puede afectar la calidad del agua.	3	5	**15 Alto**
R05	Filtración masiva de datos personales de clientes	A05, A04	V01, V03, V07	Doble extorsión habitual; en 2022 se robaron datos de más de 40 equipos [16]. 3,05 M de titulares.	4	5	**20 Crítico**
R06	Toma del Directorio Activo	A07, A09	V04, V05	Requiere acceso inicial; si ocurre, el atacante controla todo el dominio y los hipervisores.	3	5	**15 Alto**
R07	Phishing, suplantación de canales y fraude de pagos	A06, A08	—	Ataque continuo; EPM atendió una suplantación del portal factura web en 2025 [14]. Pérdida contenible.	5	3	**15 Alto**

ID	Riesgo	Activos	CVE	Justificación de P e I	P	I	Nivel
R08	Destrucción o cifrado de respaldos	A10, A09	V06, V05	Los atacantes buscan primero los respaldos; en 2022 se reportó su pérdida [17]. Sin respaldo no hay recuperación.	3	5	**15 Alto**
R09	Compromiso del ERP SAP	A03	V07	CVE en KEV y migración a S/4HANA en curso [15]. Fraude en pagos y robo de contratos.	3	4	**12 Alto**
R10	Toma de routers de la red operativa	A12	V08	Explotación masiva de interfaces web en 2023. Se pierde comunicación con subestaciones y se opera manual.	3	4	**12 Alto**
R11	Incidente en un proveedor con acceso a sistemas	A01, A02, A03	—	Integradores OT y soporte SCADA con accesos permanentes y cuentas compartidas [S].	3	4	**12 Alto**
R12	Exposición de datos reales en ambientes de prueba	A05	—	Migraciones de S/4HANA y AMI [15] sin regla de enmascaramiento (RI-06). Copias parciales.	3	3	**9 Medio**

Resumen inherente: 2 críticos (R01, R05), 9 altos (R02, R03, R04, R06, R07, R08, R09, R10, R11) y 1 medio (R12).

6. Actividad 5: Matriz de evaluación y tratamiento del riesgo

La matriz se divide en dos tablas para que se pueda leer en A4: la primera describe el escenario y la segunda la decisión de tratamiento. Los controles propuestos remiten a las acciones AC del plan (sección 8).

Tabla 11a. Escenario de riesgo: activo, amenaza, vulnerabilidad y controles existentes.

ID	Activos	Amenaza	Vulnerabilidad	Controles existentes	Inherente
R01	A04, A06, A07, A09, A10	Grupo de ransomware como servicio (RaaS)	V03–V06; privilegios amplios [S]	SOC y plan estratégico de ciberseguridad [7, 15]; DRP en actualización [12]; antivirus en equipos [S]	**4×5=20**
R02	A11	Explotación masiva de equipos de borde	V01, V02; MFA no universal [S]	Firewalls y VPN [S]; gestión de vulnerabilidades del SOC [7]	**4×4=16**
R03	A01, A12	Actor estatal o criminal con capacidad OT	V10, V08; conexiones TI–OT [S]	Guía de ciberseguridad del CNO y auditorías TO [6, 14]; segmentación parcial [S]	**3×5=15**
R04	A02	Hacktivistas que buscan PLC expuestos	V09; contraseñas por defecto [S]	Personal de operación en planta [S]; auditoría SCADA [14]	**3×5=15**
R05	A05, A04	Extorsión con publicación de datos	V01, V03, V07; bases sin cifrar [S]	Lineamiento de datos personales con medidas por niveles [8]; SOC [7]	**4×5=20**
R06	A07, A09	Escalamiento de privilegios tras acceso inicial	V04, V05; cuentas admin en uso diario [S]	Revisión de calidad de contraseñas (auditoría 2021) [14]; SOC [7]	**3×5=15**
R07	A06, A08	Phishing, portales falsos, fraude BEC	Sin verificación por doble canal ni DMARC estricto [S]	Atención de la suplantación de factura web (2025) [14]; política de cero tolerancia al fraude [11]	**5×3=15**
R08	A10, A09	Borrado de respaldos antes del cifrado	V06, V05; servidor de respaldo en el dominio [S]	Centro alterno de procesamiento (CAPD) [14]; DRP [12]	**3×5=15**
R09	A03	Explotación de SAP expuesto	V07; parches SAP tardíos [S]	Controles financieros y auditoría interna [14]	**3×4=12**
R10	A12	Explotación de interfaces web de routers	V08; HTTP habilitado [S]	Enlaces redundantes [S]	**3×4=12**
R11	A01, A02, A03	Proveedor comprometido usado como puente	Accesos permanentes y cuentas compartidas [S]	Política de relacionamiento con proveedores [5]; cláusulas de datos personales [8]	**3×4=12**
R12	A05	Fuga desde ambientes no productivos o terceros	Copias reales sin enmascarar [S]	Lineamiento de datos personales [8]	**3×3=9**

Tabla 11b. Tratamiento, controles propuestos, responsables, plazos y riesgo residual esperado.

ID	Tratamiento	Controles propuestos (acción · Anexo A)	Responsable [S]	Plazo	Residual (P×I)
R01	Mitigar y transferir (póliza ciber)	AC-01, AC-03, AC-04, AC-06, AC-11 · 5.17, 8.2, 8.13, 8.16, 5.26	Director de Ciberseguridad	0–12 meses	**2×4=8 Medio**
R02	Mitigar	AC-01, AC-02 · 8.5, 8.8, 8.20	Jefe de Redes y Seguridad Perimetral	0–3 meses	**2×4=8 Medio**
R03	Mitigar	AC-05, AC-06, AC-10, AC-11 · 8.22, 8.20, 5.15, 5.21	Gerente de Operación de Energía	0–12 meses	**2×5=10 Alto**
R04	Mitigar	AC-02, AC-05 · 8.22, 8.9, 5.17	Gerente de Provisión de Aguas	0–6 meses	**1×5=5 Medio**
R05	Mitigar y transferir (póliza ciber)	AC-01, AC-06, AC-08 · 8.24, 8.12, 5.34, 8.16	Jefe de la Unidad de Cumplimiento	0–12 meses	**2×4=8 Medio**
R06	Mitigar	AC-03, AC-06 · 8.2, 5.18, 8.5	Jefe de Infraestructura TI	3–12 meses	**1×5=5 Medio**
R07	Mitigar	AC-07 · 5.14, 5.7, 6.3	Jefe de Canales Digitales y VP Finanzas	0–6 meses	**3×2=6 Medio**
R08	Mitigar	AC-03, AC-04 · 8.13, 8.14, 5.30	Jefe de Continuidad de TI	0–9 meses	**1×4=4 Bajo**
R09	Mitigar	AC-02, AC-09 · 8.8, 8.9, 5.3	Gerente de Tecnologías y Procesos	0–6 meses	**2×3=6 Medio**
R10	Mitigar	AC-02 · 8.20, 8.9	Jefe de Telecomunicaciones	0–3 meses	**1×4=4 Bajo**
R11	Mitigar	AC-05, AC-10 · 5.19, 5.20, 5.22	Gerente de Abastecimiento	0–12 meses	**2×3=6 Medio**
R12	Evitar (eliminar la práctica)	AC-08 · 8.11, 8.31, 8.33	Jefe de la Unidad de Cumplimiento	6–12 meses	**1×3=3 Bajo**

El impacto baja solo cuando el control limita el daño (respaldos inmutables, cifrado, segmentación, verificación de pagos). En R03, R04 y R06 el impacto no baja porque, si el evento ocurre, la consecuencia sigue siendo máxima; ahí se reduce sobre todo la probabilidad.

7. Actividad 6: Mapa de calor inherente y residual

Cada celda tiene el valor P×I y su color: verde = bajo (1–4), amarillo = medio (5–9), naranja = alto (10–16) y rojo = crítico (20–25). Los riesgos se ubican según las tablas 10 y 11b.

Figura 1a. Riesgo inherente

P \ I	1	2	3	4	5
5	5	10	15 **R07**	20	25
4	4	8	12	16 **R02**	20 **R01 R05**
3	3	6	9 **R12**	12 **R09 R10 R11**	15 **R03 R04 R06 R08**
2	2	4	6	8	10
1	1	2	3	4	5

Figura 1b. Riesgo residual esperado

P \ I	1	2	3	4	5
5	5	10	15	20	25
4	4	8	12	16	20
3	3	6 **R07**	9	12	15
2	2	4	6 **R09 R11**	8 **R01 R02 R05**	10 **R03**
1	1	2	3 **R12**	4 **R08 R10**	5 **R04 R06**

Tabla 12. Conteo de riesgos por nivel.

Nivel	Inherente	Residual esperado
Crítico (20–25)	2 (R01, R05)	0
Alto (10–16)	9	1 (R03)
Medio (5–9)	1 (R12)	8
Bajo (1–4)	0	3 (R08, R10, R12)
Total	**12**	**12**

El mapa inherente se concentra en la parte alta y derecha porque EPM opera infraestructura crítica y ya sufrió un ataque. Después del plan ningún riesgo queda crítico. R03 se mantiene alto porque el impacto de un sabotaje al SCADA de energía no se puede reducir con controles de TI; por eso se propone aceptarlo de forma explícita en la junta y revisarlo cada trimestre.

8. Actividad 7: Plan de tratamiento de riesgos

El plan tiene 11 acciones en 12 meses. Los montos son estimaciones ficticias [S] que incluyen licencias, servicios e implementación; no incluyen la póliza de ciberriesgo, que se cotiza aparte.

Tabla 13. Plan de tratamiento (recursos en millones de COP [S]).

ID	Acción concreta	Anexo A	Responsable [S]	Recursos	Plazo	Indicador (meta)	Riesgos
AC-01	MFA resistente a phishing en VPN, correo, consolas y cuentas privilegiadas; bloquear autenticación heredada; reautenticación en sesiones VPN.	5.17, 8.5	Director de Ciberseguridad	900	0–3 m	% de cuentas con MFA (100 % privilegiadas y remotas; 98 % del total).	R01, R02, R05
AC-02	Gestión de la superficie expuesta (RI-03): escaneo externo mensual, cierre de interfaces de administración y parcheo de vulnerabilidades KEV en equipos de borde, routers, SAP y PLC.	5.9, 8.8, 8.9, 8.20	Jefe de Redes y Seguridad Perimetral	350	0–3 m y continuo	KEV en activos expuestos corregidas en ≤ 7 días (100 %); interfaces admin expuestas (0).	R02, R04, R09, R10
AC-03	Administración por niveles (RI-02): bóveda de credenciales (PAM) con sesión grabada, estaciones de administración, ESXi y respaldos fuera del dominio, AD CS endurecido.	5.18, 8.2, 8.5	Jefe de Infraestructura TI	1.200	3–9 m	Cuentas con privilegio de dominio (−80 %); sesiones admin por PAM (100 %).	R01, R06, R08
AC-04	Respaldos 3-2-1-1-0: copia inmutable y otra fuera de línea; Veeam actualizado; prueba trimestral de restauración, incluido un Directorio Activo limpio.	8.13, 8.14, 5.30	Jefe de Continuidad de TI	1.500	0–6 m	Sistemas críticos con copia inmutable (100 %); RTO probado de prepago ≤ 24 h.	R01, R08
AC-05	Segmentación TI/OT por zonas y conductos (IEC 62443) con DMZ industrial y bastión (RI-01); retirar PLC/HMI de internet y cambiar contraseñas por defecto en 30 días.	5.15, 8.20, 8.22	Gerentes de Operación de Energía y de Aguas	3.500	0–12 m	Plantas con segmentación validada (100 %); conexiones remotas OT fuera del bastión (0).	R03, R04, R11
AC-06	Registros al SOC con retención de 12 meses (RI-04) y monitoreo pasivo de redes OT integrado al SOC.	8.15, 8.16, 8.17	Director de Ciberseguridad (SOC)	1.800	3–12 m	Fuentes críticas enviando registros (95 %); tiempo de detección < 24 h.	R01, R03, R05, R06
AC-07	Antifraude y marca (RI-05): DMARC *reject*, baja de sitios falsos, verificación de pagos por doble canal y simulaciones de phishing trimestrales.	5.7, 5.14, 6.3	Jefe de Canales Digitales y VP Finanzas	400	0–6 m	Clic en simulaciones < 5 %; baja de sitios falsos < 24 h; pagos fraudulentos (0).	R07

ID	Acción concreta	Anexo A	Responsable [S]	Recursos	Plazo	Indicador (meta)	Riesgos
AC-08	Protección de datos de clientes: cifrado de bases, prevención de fuga (DLP) y enmascaramiento en ambientes no productivos (RI-06).	5.34, 8.11, 8.12, 8.24, 8.33	Jefe de la Unidad de Cumplimiento	900	6–12 m	Bases de clientes cifradas (100 %); ambientes no productivos sin datos reales (100 %).	R05, R12
AC-09	Seguridad SAP: notas de seguridad mensuales, desactivar componentes no usados, segregación de funciones y monitoreo de transacciones críticas.	5.3, 8.8, 8.9	Gerente de Tecnologías y Procesos	600	0–6 m	Notas «Hot News» aplicadas en ≤ 30 días (100 %); conflictos de segregación (−90 %).	R09
AC-10	Proveedores con acceso: anexo de seguridad (aviso de incidentes en 24 h, MFA, derecho de auditoría), cuentas nominales con vencimiento y evaluación anual de integradores OT.	5.19, 5.20, 5.21, 5.22	Gerente de Abastecimiento	300	3–12 m	Contratos críticos con anexo (100 %); proveedores críticos evaluados (100 %).	R03, R11
AC-11	Respuesta a incidentes: guías para ransomware y OT, contrato de respuesta con un tercero, operación manual de prepago y simulacro anual con la junta.	5.24, 5.26, 5.27, 5.29	Director de Ciberseguridad y VP Riesgos	700	0–6 m	Simulacros al año (≥ 2); activación del comité de crisis < 1 h.	R01, R03
			Total	**12.150**			

8.1 Resultados esperados por fase

Tabla 14. Reducción esperada del riesgo por fase (inherente → residual).

Fase	Acciones principales	Riesgos que bajan
Fase 1 (0–3 meses)	AC-01, AC-02 y primeras tareas de AC-05, AC-07 y AC-11	R02 (16 → 8) y R10 (12 → 4). Se cierran los accesos más expuestos.
Fase 2 (3–6 meses)	AC-04, AC-07, AC-09, AC-11 y AC-05 en agua	R04 (15 → 5), R07 (15 → 6) y R09 (12 → 6).
Fase 3 (6–12 meses)	AC-03, AC-05 en energía, AC-06, AC-08 y AC-10	R01 (20 → 8), R03 (15 → 10), R05 (20 → 8), R06 (15 → 5), R08 (15 → 4), R11 (12 → 6) y R12 (9 → 3).

El seguimiento se haría con un tablero trimestral para el Comité de Auditoría y Riesgos de la Junta con los indicadores de la Tabla 13. Para la gestión del sistema, los controles nuevos se agregan a la declaración de aplicabilidad del SGSI que EPM menciona en sus documentos [6, 8].

9. Actividad 8: Caso de incidente (escenario ficticio [S])

9.1 Contexto

Un viernes de puente festivo un grupo de ransomware como servicio usa un token de sesión robado de un controlador de acceso remoto sin parchear (tipo V01) y entra como un contratista de soporte, sin que se le pida MFA. Durante la noche explora la red, usa una falla tipo V04 para hacerse administrador del dominio, desactiva el antivirus y copia 380 GB de servidores de archivos y de una réplica de la base de clientes (A05). El domingo a las 02:00 cifra el clúster de virtualización (A09) que soporta el sistema comercial, el portal y las recargas de prepago. Solo el 60 % de los sistemas tenía copia inmutable. Los centros de control OT siguen operando porque están en otra red, pero comparten algunos servicios de dominio [S].

Tabla 15. Línea de tiempo del escenario [S].

Momento	Evento
Viernes 21:40	Inicio de sesión VPN del contratista desde una IP extranjera reutilizando una sesión válida.
Sábado 03:15	Creación de una cuenta y emisión de un certificado anómalo en AD CS; el SOC lo registra como alerta media sin escalar.
Sábado 04:00–18:00	Salida de 380 GB hacia un servicio de almacenamiento en la nube.
Domingo 02:00	Apagado y cifrado de 140 máquinas virtuales; nota de rescate con amenaza de publicar datos.
Domingo 02:20	El SOC detecta el apagado masivo; 02:50 se activa el comité de crisis.

9.2 Contención (primeras 6 horas)

- Cortar la VPN y las conexiones a internet del centro de datos; deshabilitar las cuentas del contratista y las creadas por el atacante; revocar el certificado emitido.
- Cerrar los conductos entre TI y OT. Los centros de control pasan a operación aislada y se verifica que la lógica de los controladores no haya cambiado.
- Aislar los hipervisores afectados sin borrarlos; tomar memoria y discos para la investigación. Proteger de inmediato el repositorio de respaldos.
- Activar la contingencia comercial: recargas de prepago por aliados externos, como se hizo en 2022 [18], y mensajes a clientes por canales oficiales.

9.3 Investigación (6 horas a 10 días)

- Activar el contrato de respuesta a incidentes (AC-11) y reconstruir la línea de tiempo con los registros centralizados (RI-04): punto de entrada, cuentas usadas, persistencia y datos copiados.
- Determinar qué datos personales salieron y de cuántos titulares, para decidir las notificaciones.
- Denuncia ante la Fiscalía por acceso abusivo, daño informático, uso de software malicioso y violación de datos personales (Ley 1273 de 2009, arts. 269A, 269D, 269E y 269F) [43]; reporte al ColCERT [44]; informe a la SSPD por la afectación del servicio.
- Reporte a la SIC de la violación de los códigos de seguridad (Ley 1581, art. 17, lit. n) [42] y aviso a los titulares afectados.
- Decisión de la junta, asesorada por el comité de crisis: no pagar el rescate [S], porque no garantiza la recuperación ni la no publicación.

9.4 Recuperación (día 1 a día 14)

- Reconstruir primero un Directorio Activo limpio desde la copia fuera de línea y rotar todas las credenciales (incluida la cuenta krbtgt dos veces).
- Restaurar por prioridad de negocio: identidades → facturación y prepago (meta 72 h [S]) → portal y app → ERP → resto. Cada servidor se revisa antes de volver a la red.
- Reabrir la VPN solo con MFA y equipos parcheados; monitoreo reforzado durante 30 días.

9.5 Prevención y lecciones aprendidas

En dos semanas se hace una revisión post-incidente (control 5.27) que alimenta el plan: parcheo de borde en 7 días y reautenticación de sesiones (AC-01, AC-02), administración por niveles y AD CS endurecido (AC-03), 100 % de copias inmutables (AC-04), alertas de AD CS escaladas automáticamente por el SOC (AC-06) y un simulacro con la junta usando este mismo escenario (AC-11).

10. Actividad 9: Conclusiones

Los tres riesgos prioritarios para EPM son:

1. **R01 – Ransomware en TI (20, crítico → 8, medio).** Ya ocurrió en 2022 y afectó a cientos de miles de familias. Las medidas que más lo reducen son MFA (AC-01), administración por niveles (AC-03) y respaldos inmutables

probados (AC-04), porque atacan los tres pasos del ataque: entrada, escalamiento y destrucción de la recuperación.

2. **R05 – Filtración de datos de 3,05 M de clientes (20, crítico → 8, medio).** Hoy el ransomware casi siempre roba datos antes de cifrar, como pasó en 2022. Además del cumplimiento de la Ley 1581, el cifrado de bases, la prevención de fuga y la prohibición de datos reales en pruebas (AC-08, RI-06) reducen cuánto se puede robar.
3. **R02 – Compromiso del acceso remoto y del perímetro (16, alto → 8, medio).** Es la puerta de entrada de los dos anteriores: V01 y V02 se explotaron en masa y no requieren contraseña. Parchear los equipos de borde en 7 días y controlar la superficie expuesta (AC-02, RI-03) es lo más barato y rápido del plan.

Además, R03 (sabotaje del SCADA de energía) es el único riesgo que queda alto. Su probabilidad es menor, pero sus efectos son físicos y nacionales, por lo que la segmentación TI/OT con bastión (AC-05, RI-01) debe tener financiación estable y seguimiento directo de la junta.

En general, EPM tiene buena base de gobierno (estrategia de ciberseguridad, SOC, DRP en desarrollo y auditorías de TO), pero sus políticas públicas son declaraciones amplias. Las seis reglas propuestas convierten esas declaraciones en obligaciones verificables. Como limitación, este análisis se hizo solo con información pública: el inventario, los responsables y los montos son supuestos y deben validarse con la información interna del SGSI de EPM.

Anexo. Controles del Anexo A de ISO/IEC 27001:2022 citados

Control	Nombre	Control	Nombre
5.3	Segregación de funciones	8.2	Derechos de acceso privilegiado
5.7	Inteligencia de amenazas	8.5	Autenticación segura
5.9	Inventario de información y otros activos asociados	8.8	Gestión de vulnerabilidades técnicas
5.14	Transferencia de información	8.9	Gestión de la configuración
5.15	Control de acceso	8.11	Enmascaramiento de datos
5.17	Información de autenticación	8.12	Prevención de fuga de datos
5.18	Derechos de acceso	8.13	Respaldo de la información
5.19	Seguridad de la información en las relaciones con proveedores	8.14	Redundancia de las instalaciones de procesamiento
5.20	Seguridad en los acuerdos con proveedores	8.15	Registro (logging)
5.21	Seguridad en la cadena de suministro de TIC	8.16	Actividades de monitoreo
5.22	Seguimiento y gestión de cambios de servicios de proveedores	8.17	Sincronización de relojes
5.24	Planificación y preparación de la gestión de incidentes	8.20	Seguridad de redes
5.26	Respuesta a incidentes	8.21	Seguridad de los servicios de red
5.27	Aprendizaje de los incidentes	8.22	Segregación de redes
5.28	Recolección de evidencia	8.24	Uso de criptografía
5.29	Seguridad de la información durante una disrupción	8.31	Separación de ambientes de desarrollo, prueba y producción
5.30	Preparación de las TIC para la continuidad del negocio	8.33	Información de prueba
5.34	Privacidad y protección de datos personales	6.3	Concienciación, educación y formación

Referencias

1. ISO/IEC. *ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection – Information security management systems – Requirements.* Ginebra: ISO, 2022.
2. ISO. *ISO 31000:2018. Risk management – Guidelines.* Ginebra: ISO, 2018.
3. ISO/IEC. *ISO/IEC 27005:2022. Guidance on managing information security risks.* Ginebra: ISO, 2022.
4. IEC. *IEC 62443-3-3:2013. Industrial communication networks – Network and system security – System security requirements and security levels.* Ginebra: IEC, 2013.
5. EPM. «Políticas» (sitio institucional). https://www.epm.com.co/institucional/sobre-epm/quienes-somos/politicas (consultado el 29/10/2026).
6. EPM. Lineamiento 2023-LINGG-115, «Proceso Seguridad Digital y Continuidad de los Servicios de Tecnología», 23/02/2023 (enlazado como Política de seguridad de la información y ciberseguridad del Grupo EPM). https://www.epm.com.co/content/dam/epm/institucional/documentos/todos/politica-de-seguridad-de-la-informacion-y-ciberseguridad-para-el-grupo-epm.pdf

7. EPM, Dirección de Ciberseguridad. «Estrategia Seguridad de la información y Ciberseguridad 2024–2027». https://www.epm.com.co/content/dam/epm/institucional/transparencia/documentos/estrategia-ciberseguridad.pdf
8. EPM. Decreto 2013-DECGGL-1946 y «Lineamiento sobre Protección de Datos Personales», rev. 003 (23/09/2019). https://www.epm.com.co/content/dam/epm/institucional/documentos/todos/politica-de-privacidad.pdf
9. EPM, Secretaría General. Certificación de la «Política de Gestión Ética y Cumplimiento» (Acta 1801 de Junta, 01/10/2024). https://www.epm.com.co/content/dam/epm/institucional/sobre-epm/qui%C3%A9nes-somos/politicas/certificado-politica-gestion-etica-y-cumplimiento.pdf
10. EPM. «Código de Ética del Grupo EPM». https://www.epm.com.co/content/dam/epm/institucional/sobre-epm/gobierno-corporativo/c%C3%B3digo-de-%C3%A9tica/codigo-etica-epm%20(1).pdf
11. EPM. «Política de cero tolerancia frente al fraude, la corrupción y el soborno». https://www.epm.com.co/content/dam/epm/institucional/documentos/todos/politica-cero-tolerancia.pdf
12. EPM, Gerencia Tecnologías y Procesos. «Plan Estratégico Integrado 2026» (PETI). https://www.epm.com.co/content/dam/epm/institucional/transparencia/documentos/gti-peti-2026.pdf
13. EPM, Secretaría de Junta Directiva. Certificación de la «Política de Seguridad de EPM» (Acta 1655, 18/12/2018). https://www.epm.com.co/content/dam/epm/institucional/documentos/todos/politica-de-seguridad-epm.pdf
14. EPM, Auditoría Corporativa. Relación de trabajos de auditoría (publicada el 10/09/2026). https://www.epm.com.co/content/dam/epm/institucional/sobre-epm/gobierno-corporativo/marco-general-de-gobierno-/mecanismos-de-contr%C3%B3l-/Informes-auditoria-10-09-2026.pdf
15. Grupo EPM. «Informe de Sostenibilidad 2025». https://sostenibilidadgrupoepm.com.co/wp-content/uploads/2026/08/V2_00_UNIF_INFORME_SOSTE_ESP_2025_.pdf
16. Abrams, L. «Colombian energy supplier EPM hit by BlackCat ransomware attack». *BleepingComputer*, 16/12/2022. https://www.bleepingcomputer.com/news/security/colombian-energy-supplier-epm-hit-by-blackcat-ransomware-attack/
17. Guerrero Arango, Á. «Gato negro: así operan los cibermercenarios que atacaron a EPM». *El Colombiano*, 18/12/2022. https://www.elcolombiano.com/antioquia/ciberataque-a-epm-fue-por-grubo-de-ciberdelincuentes-blackcat-ML19657803
18. Valora Analitik. «Ciberataque a EPM: ¿qué ha pasado con las investigaciones y soluciones?», 21/12/2022. https://www.valoraanalitik.com/ciberataque-a-epm-que-ha-pasado-con-las-investigaciones-y-soluciones/
19. CISA. «Known Exploited Vulnerabilities Catalog», versión 2026.10.29. https://www.cisa.gov/known-exploited-vulnerabilities-catalog
20. NIST NVD. CVE-2023-4966. https://nvd.nist.gov/vuln/detail/CVE-2023-4966
21. Citrix. CTX579459, «NetScaler ADC and NetScaler Gateway Security Bulletin for CVE-2023-4966 and CVE-2023-4967». https://support.citrix.com/article/CTX579459
22. CISA. AA23-325A, «#StopRansomware: LockBit 3.0 Ransomware Affiliates Exploit CVE 2023-4966 Citrix Bleed Vulnerability», 21/11/2023. https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-325a
23. NIST NVD. CVE-2024-3400. https://nvd.nist.gov/vuln/detail/CVE-2024-3400
24. Palo Alto Networks. «CVE-2024-3400 PAN-OS: Arbitrary File Creation Leads to OS Command Injection Vulnerability in GlobalProtect». https://security.paloaltonetworks.com/CVE-2024-3400
25. NIST NVD. CVE-2022-41082. https://nvd.nist.gov/vuln/detail/CVE-2022-41082
26. Microsoft MSRC. «CVE-2022-41082 Microsoft Exchange Server Remote Code Execution Vulnerability». https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-41082
27. NIST NVD. CVE-2022-26923. https://nvd.nist.gov/vuln/detail/CVE-2022-26923
28. Microsoft MSRC. «CVE-2022-26923 Active Directory Domain Services Elevation of Privilege Vulnerability». https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-26923
29. NIST NVD. CVE-2024-37085. https://nvd.nist.gov/vuln/detail/CVE-2024-37085
30. Broadcom (VMware). VMSA-2024-0013. https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/24505
31. Microsoft Threat Intelligence. «Ransomware operators exploit ESXi hypervisor vulnerability for mass encryption», 29/07/2024. https://www.microsoft.com/en-us/security/blog/2024/07/29/ransomware-operators-exploit-esxi-hypervisor-vulnerability-for-mass-encryption/
32. NIST NVD. CVE-2024-40711. https://nvd.nist.gov/vuln/detail/CVE-2024-40711
33. Veeam. KB4649, «Veeam Security Bulletin (September 2024)». https://www.veeam.com/kb4649
34. NIST NVD. CVE-2025-31324. https://nvd.nist.gov/vuln/detail/CVE-2025-31324
35. Onapsis. «Active Exploitation of SAP Vulnerability CVE-2025-31324». https://onapsis.com/blog/active-exploitation-of-sap-vulnerability-cve-2025-31324/
36. NIST NVD. CVE-2023-20198. https://nvd.nist.gov/vuln/detail/CVE-2023-20198
37. Cisco. «Multiple Vulnerabilities in Cisco IOS XE Software Web UI Feature» (cisco-sa-iosxe-webui-privesc-j22SaA4z). https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-iosxe-webui-privesc-j22SaA4z
38. NIST NVD. CVE-2023-6448. https://nvd.nist.gov/vuln/detail/CVE-2023-6448
39. CISA. «Exploitation of Unitronics PLCs used in Water and Wastewater Systems», 28/11/2023. https://www.cisa.gov/news-events/alerts/2023/11/28/exploitation-unitronics-plcs-used-water-and-wastewater-systems
40. NIST NVD. CVE-2021-22681. https://nvd.nist.gov/vuln/detail/CVE-2021-22681
41. CISA. ICSA-21-056-03, «Rockwell Automation Logix Controllers (Update A)». https://www.cisa.gov/news-events/ics-advisories/icsa-21-056-03
42. Congreso de la República de Colombia. Ley 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales. http://www.secretariasenado.gov.co/senado/basedoc/ley_1581_2012.html
43. Congreso de la República de Colombia. Ley 1273 de 2009, por medio de la cual se modifica el Código Penal y se crea el bien jurídico de la protección de la información y de los datos. http://www.secretariasenado.gov.co/senado/basedoc/ley_1273_2009.html
44. Presidencia de la República de Colombia. Decreto 338 de 2022, lineamientos para fortalecer la gobernanza de la seguridad digital.